Le site livré par l'IA est-il en règle ?

BTS SIO 1ère année

Fil rouge VPI — jalon 0 : auditer puis corriger un site généré par un agent IA

Présence en ligne & cybersécurité

Objectifs

- Repérer, avec les outils du navigateur, les données qu'une page envoie à des tiers.
- Relier chaque défaut constaté au DICP ou à un principe du RGPD, preuve à l'appui.
- Corriger soi-même le code livré et vérifier que la correction fonctionne.

Prérequis

- DICP et RGPD (Bloc 3, SQ01 et SQ02).
- Lire du HTML, ouvrir les outils de développement, sélectionner un élément du DOM (Bloc 1, SQ03).

Sommaire

Partie	Contenu
Matin — Bloc 3	Auditer le site livré (étapes 1 à 5)
Après-midi — Bloc 1	Corriger le site (étapes 6 à 9)

Le contexte

Vermand Prévention Ingénierie (VPI) est un bureau d'études de Saint-Quentin : il analyse les postes de travail dans l'industrie, conçoit des dispositifs de prévention et forme les équipes. VPI a confié son nouveau site vitrine à **Soft-Tech**. Un alternant de Soft-Tech l'a fait générer par un **agent IA**, en quelques minutes.

Le client est ravi, mais sa responsable qualité demande : « Est-ce qu'on est vraiment en règle ? » Soft-Tech vous confie la vérification **avant la mise en ligne**.

> **Repère**
>
> VPI, ses clients et ses coordonnées sont fictifs. Le site ne fonctionne qu'en local : rien n'est réellement envoyé à VPI.

Consignes générales

En binôme sur un poste, trace individuelle sur papier. L'un manipule, l'autre note et vérifie ; inversez à chaque étape. **IA interdite** : vous êtes justement là pour vérifier ce qu'une IA a produit.

Téléchargez et décompressez `site-livre-ia.zip`. Il contient le site (`index.html`, `style.css`, `script.js`) et `LIVRAISON.md`, l'échange entre l'alternant et l'agent.

Matin — Auditer le site livré

BTS SIO 1ère année

Fil rouge VPI — jalon 0 : auditer puis corriger un site généré par un agent IA

Présence en ligne & cybersécurité

Étape 1 — Lire la livraison

5 minutes. Ouvrez `LIVRAISON.md`, puis `index.html` dans le navigateur.

Relevez **trois promesses** de l'agent que vous allez devoir vérifier. Notez aussi ce que la demande de l'alternant contenait de risqué : l'IA a-t-elle fait seulement ce qu'on lui a demandé ?

Étape 2 — Ce que la page envoie ailleurs

12 minutes. Ouvrez les outils de développement (`F12`), onglet **Réseau**, puis rechargez la page (`Ctrl + Maj + R`).

Chaque ligne est un fichier demandé par la page. Triez par **domaine**. Pour chaque domaine qui n'est pas le site lui-même, complétez :

Domaine contacté	Service rendu	Ce qui part au minimum chez ce tiers

> **Aide si vous bloquez.** Une requête vers un serveur lui révèle toujours au moins **l'adresse IP** du visiteur, la page visitée et le navigateur utilisé. Une adresse IP est-elle une donnée personnelle ?

Étape 3 — Le formulaire de contact

12 minutes. Remplissez le formulaire avec une **identité inventée** (jamais vos vraies données), puis envoyez-le. La page d'erreur est normale : le serveur de VPI n'existe pas.

1. Regardez la **barre d'adresse**. Où se trouvent vos données ? Comment circulent-elles ?
2. Revenez en arrière. Onglet **Console** : qu'est-ce qui est affiché ?
3. Onglet **Application** (Chrome) ou **Stockage** (Firefox), puis **Stockage local** : qu'est-ce qui est conservé dans le navigateur ?
4. Rechargez la page. Imaginez ce poste à l'accueil d'un salon professionnel : que voit le visiteur suivant ?
5. Relisez chaque champ et la case à cocher : tout est-il **nécessaire** pour rappeler un prospect ? Le consentement est-il **libre** ?

Étape 4 — Lire le code source

8 minutes. Ouvrez les trois fichiers dans VS Code. Cherchez (`Ctrl + F`) ce qu'un développeur n'aurait jamais dû laisser dans du code destiné à être publié.

> **Aide si vous bloquez.** Cherchez les mots `TODO`, `mot de passe`, `KEY`. Puis demandez-vous : qui peut lire ces fichiers une fois le site en ligne ?

Étape 5 — Le rapport d'audit

8 minutes, puis mise en commun. Rassemblez vos constats dans un tableau. Chaque ligne doit avoir une **preuve** : l'onglet, le fichier ou la ligne où vous l'avez vu.

Constat	Preuve (où)	DICP ou principe RGPD	Gravité (1 à 3)	Correction proposée

Puis rédigez pour la responsable qualité **trois phrases** : peut-on mettre le site en ligne aujourd'hui ? Quels sont les deux défauts à corriger en premier, et pourquoi ?

Critère de réussite du matin : au moins **six constats** prouvés, reliés au DICP ou au RGPD, et une recommandation argumentée au client.

> **Pour aller plus loin.** Onglet Réseau, clic droit sur la ligne `jquery` puis **Bloquer l'URL de la requête** (Chrome) ou **Bloquer l'URL** (Firefox). Rechargez la page en largeur de téléphone et essayez le menu. Quel critère du DICP est touché quand un service extérieur tombe en panne ?

Après-midi — Corriger le site

BTS SIO 1ère année

Fil rouge VPI — jalon 0 : auditer puis corriger un site généré par un agent IA

Présence en ligne & cybersécurité

Consignes

Travaillez sur une **copie** du dossier (`site-corrige/`) : gardez l'original pour comparer. Après chaque étape, rechargez la page et vérifiez qu'elle fonctionne encore.

Étape 6 — Supprimer les secrets

5 minutes. Retirez le commentaire du back-office et la clé de l'API.

Supprimer la ligne suffit-il ? Si ces fichiers avaient déjà été en ligne, que faudrait-il faire en plus avec le mot de passe et la clé ?

Étape 7 — Plus aucun tiers au chargement

12 minutes.

1. Supprimez le code de Google Analytics **et** la fonction qui l'utilise dans `script.js` .
2. Supprimez les polices Google. Dans `style.css` , remplacez les deux polices par une pile de polices système : `system-ui, sans-serif` .
3. Remplacez la carte Google Maps par un **lien** « Voir le plan d'accès » : la carte ne se charge que si le visiteur le décide.

Vérification : onglet Réseau, rechargement forcé. Il ne reste que des fichiers du site… et jQuery. On s'en occupe à l'étape 9.

Étape 8 — Un formulaire conforme

15 minutes.

1. Retirez les champs qui ne servent pas à **rappeler un prospect**.
2. Décochez la case newsletter et séparez-la des offres des partenaires : un consentement par finalité.
3. Passez le formulaire en `method="post"` et l'adresse d'envoi en `https://` .
4. Remplacez la phrase sous le bouton par une **mention d'information** (à adapter) :

> Les informations recueillies sont utilisées par Vermand Prévention Ingénierie pour répondre à votre demande de diagnostic. Elles sont conservées trois ans après notre dernier contact. Vous pouvez y accéder, les faire rectifier ou effacer en écrivant à rgpd@vermand-ingenierie.example. En cas de difficulté, vous pouvez saisir la CNIL.

5. Dans `script.js`, supprimez l'enregistrement dans le stockage local, l'affichage dans la console et le pré-remplissage.

Étape 9 — Se passer de jQuery

Si vous avez le temps ; sinon, au prochain jalon. jQuery ne sert plus qu'au menu mobile et au défilement. Remplacez-le par ce que vous connaissez du DOM :

1. Défilement fluide : une seule ligne CSS suffit, `html { scroll-behavior: smooth; }`.
2. Menu mobile : sélectionner le bouton `.burger`, écouter le clic, et basculer la classe `ouvert` sur `.menu`.
3. Supprimez la balise `<script>` de jQuery et tout le code `$(…)`.

> **Aide si vous bloquez.** Les trois mots utiles : `document.querySelector`, `addEventListener`, `classList.toggle`. Retrouvez-les dans le TP du DOM.

Critère de réussite de l'après-midi : au rechargement, l'onglet Réseau ne montre plus aucune requête vers un tiers en dehors de jQuery, et le formulaire ne demande que le nécessaire. L'étape 9 retire ce dernier tiers.

Vérification avant de montrer votre travail

- [ ] Aucun mot de passe ni aucune clé ne reste dans les trois fichiers.
- [ ] Au rechargement, aucune requête ne part vers Google ou MailPulse ; la carte attend un clic.
- [ ] Le formulaire : champs utiles seulement, case non pré-cochée, POST en HTTPS, mention d'information.
- [ ] Rien n'est conservé dans le stockage local ni affiché dans la console.
- [ ] Je sais expliquer chaque correction avec un critère du DICP ou un principe du RGPD.

Conservez le dossier `site-corrige/` : c'est lui qui sera mis en ligne sur votre serveur Apache dans les prochains jalons.